Security for Cloud Computing

Unit-5A

Cloud in IT

- The Paradigm Shift: Traditional IT required organizations to buy, build, and maintain physical hardware, local data centres, and dedicated networking gear (Capital Expenditure or CapEx). Cloud computing transforms this into an elastic, utility-based operational expenditure (OpEx) model.
- The Shared Responsibility Model: Security in the cloud is a joint effort between the cloud service provider (CSP) and the customer.
    - *CSP Responsibility ("Security of the cloud"):* Protecting the underlying global infrastructure—physical data centres, compute hardware, storage nodes, network fabrics, and virtualization hypervisors.
    - *Customer Responsibility ("Security in the cloud"):* Securing guest operating systems, application code, identity and access management (IAM), data classification, encryption configurations, and network firewall rules.

Cloud General Challenges

- Multi-Tenancy Risks: Physical hardware and memory spaces are shared among multiple untrusted corporate tenants, increasing the vector for lateral movement if isolation fails.
- Loss of Direct Physical Control: Enterprises relinquish direct physical access to their servers, making physical auditing, hardware disposal verification, and localized incident response dependent entirely on provider telemetry and SLAs.
- Insecure APIs and Interfaces: Cloud services are managed, provisioned, and automated via external web APIs. Poorly secured or unauthenticated management APIs expose control planes to interception and abuse.
- Insider Threats: Malicious or negligent internal employees at the cloud provider or within the tenant organization possess privileged access that can bypass perimeter defenses.

Security Aspects

Data Centre Security

- Physical Perimeter Defense: Hyperscale cloud data centres employ multi-layered physical security, including reinforced perimeter fences, automated bollards, biometric entry locks, 24/7 armed patrols, and closed-circuit television (CCTV) coverage with motion-tracking analytics.
- Environmental & Power Controls: Redundant power distribution units (PDUs), uninterruptible power supplies (UPS), diesel backup generators, and advanced fire suppression systems (e.g., inert gas flooding) designed to protect hardware without water damage.

Access Control

- Identity and Access Management (IAM): Centralized governance framework defining who can access what resource under what condition.
- Principle of Least Privilege (PoLP): Users, microservices, and applications are granted only the bare-minimum permissions necessary to perform their specific tasks.
- Multi-Factor Authentication (MFA): Mandatory enforcement of secondary verification mechanisms (hardware tokens, authenticator apps, biometrics) for all administrative and production access accounts.

Encryption and Decryption

- Data at Rest: Encrypting stored data on disk using robust symmetric ciphers (such as AES-256) combined with secure Key Management Services (KMS) where customers can manage or bring their own keys (BYOK).
- Data in Transit: Protecting data moving across public networks or internal data centre fabrics using strong cryptographic protocols like TLS 1.3 and IPsec tunnels.
- Data in Use (Confidential Computing): Utilizing hardware-based Trusted Execution Environments (TEEs) and secure enclaves to encrypt data while it is actively being processed in CPU memory.

Virtualization Security

- Hypervisor Vulnerabilities: Because the hypervisor controls all guest virtual machines, any zero-day exploit in the hypervisor kernel can compromise every tenant running on that physical host.
- VM Escape: A sophisticated attack vector where malicious code executing inside a guest virtual machine breaks out of its isolation boundary to compromise the underlying host OS or neighboring VMs.
- Guest Hardening: Ensuring virtual machine images are stripped of unnecessary packages, patched regularly, and isolated using micro-segmentation virtual switches.

Network Security

- Virtual Private Clouds (VPCs): Logically isolated, private network environments provisioned within the public cloud, giving customers complete control over IP address ranges, subnets, and routing tables.
- Security Groups and Network ACLs: Stateful and stateless software-defined virtual firewalls applied at the instance and subnet levels to filter inbound and outbound traffic based on ports, protocols, and source/destination IPs.
- DDoS Mitigation: Automated cloud-native scrubbing centers (e.g., AWS Shield, Cloudflare) that detect and absorb volumetric, protocol, and application-layer Distributed Denial of Service attacks before they impact backend servers.

Platform Related Security

- Security Issues in Cloud Service Models
- The security burden shifts dynamically depending on the service model:
    - IaaS (Infrastructure as a Service): Customer manages OS, middleware, runtime, data, and applications.
    - PaaS (Platform as a Service): Provider manages infrastructure, OS, and runtime; customer manages application code and data configurations.
    - SaaS (Software as a Service): Provider manages almost everything; customer is primarily responsible for user access governance and data classification.

SaaS Security Issues

- Data Leakage via Misconfiguration: Unintentional public sharing links on cloud collaboration or document storage platforms (e.g., public S3-equivalent buckets or shared drives).
- Browser-Based Vulnerabilities: Exposure to session hijacking, cross-site scripting (XSS), and credential stuffing attacks since SaaS applications are accessed directly via web browsers.
- Lack of Visibility (Shadow IT): Employees utilizing unauthorized SaaS productivity tools without corporate IT or security oversight, leading to unmonitored data exposure.

PaaS Security Issues

- Middleware Vulnerabilities: Unpatched application servers, database engines, or runtime environments managed by the platform can introduce exploitable software flaws.
- Insecure Application Runtime: Vulnerabilities in custom developer code (such as SQL injection, broken object-level authorization) deployed onto the managed platform.
- API Security Gaps: Unsecured or undocumented REST/GraphQL endpoints exposed by PaaS applications that lack rate limiting or proper token validation.

IaaS Security Issues

- Cloud Storage Misconfigurations: Leaving cloud object storage buckets with default public read/write permissions, resulting in massive data breaches.
- Root Account Compromise: Failure to secure root credentials, leaving the entire cloud subscription vulnerable to malicious cryptocurrency mining resource hijacking or data deletion.
- Unpatched Base Images: Deploying virtual machine instances from outdated or stale Golden Images that contain known, unmitigated OS-level vulnerabilities.

Audit and Compliance

Disaster Recovery

- Recovery Point Objective (RPO) & Recovery Time Objective (RTO): Defining maximum acceptable data loss duration (RPO) and maximum downtime duration (RTO) during a catastrophic failure.
- Multi-Region Replication: Continuously replicating critical database transactions and block storage snapshots across geographically separated cloud availability zones or regions to survive regional outages.
- Failover Orchestration: Automated scripts and DNS routing mechanisms (e.g., Route 53 health checks) that redirect user traffic to secondary failover regions seamlessly during an incident.

Privacy and Integrity

- Data Sovereignty & Compliance Frameworks: Adhering to strict regulatory frameworks such as GDPR, HIPAA, PCI-DSS, and SOC 2, ensuring that data residency laws restricting cross-border data transfer are strictly obeyed.
- Cryptographic Integrity Verification: Using cryptographic hashing algorithms (like SHA-256) and digital signatures to verify that stored or transmitted data has not been altered or tampered with maliciously.
- Audit Logging & SIEM Integration: Centralized ingestion of cloud control plane logs (e.g., AWS CloudTrail, Azure Monitor) into Security Information and Event Management systems to detect anomalous API calls and unauthorized security group modifications in real time.